

Cloud Security Checklist

for Kenyan SMEs — 40 points across 6 categories

This is the same checklist CloudGrid Africa uses as the opening step of every client security engagement. Work through each section — a genuinely secure Kenyan SME should be able to check off the large majority of these before considering itself audit-ready.

Sourced from NIST Cybersecurity Framework, CIS Controls v8, OWASP Top 10, the Kenya Data Protection Act 2019, ISO 27001, and current CISA guidance — each item below cites its source. Reviewed by Denis Murila, Founder & Lead Cloud Architect, CloudGrid Africa.

1. Network & Firewall Configuration Review

- ☐ Default-deny inbound firewall policy, with an explicit allow-list only for required ports/services.
CIS Control 4 · NIST CSF PR.AC
- ☐ All firewall rules documented with a business justification and last-reviewed date; unused rules removed within 90 days.
CIS Control 4
- ☐ Remote admin access (SSH/RDP) restricted to VPN or bastion host — never exposed directly to the public internet.
NIST CSF PR.AC-3
- ☐ Network segmentation separates production, staging, and internal admin networks (VLANs / VPC subnets).
CIS Control 12
- ☐ Intrusion Detection/Prevention (IDS/IPS) or cloud-native equivalent (GuardDuty, Defender) enabled and actively alerting.
NIST CSF DE.CM
- ☐ All network devices running current firmware — none past vendor end-of-life support.
CIS Control 7
- ☐ DDoS protection enabled at the edge for all internet-facing services (CDN/WAF or ISP-level).
OWASP Top 10 — A05

2. Cloud Access Control & IAM Audit

- ☐ Multi-factor authentication (MFA) enforced on every privileged/admin account, no exceptions.
CIS Control 6 · NIST CSF PR.AC-7
- ☐ Least-privilege applied — no user or service account holds broader permissions than its role requires.
CIS Control 6

- ☐ Root/root-equivalent account not used for daily operations; hardware MFA key attached to it specifically.
AWS/Azure Well-Architected
- ☐ Access reviewed and recertified at least quarterly; departed staff access revoked within 24 hours.
ISO 27001 A.9.2
- ☐ Service accounts and API keys rotated on a defined schedule (90 days) — never hardcoded in source code.
OWASP Top 10 — A07
- ☐ Just-in-time/temporary elevated access used for admin tasks instead of standing privileged accounts, where supported.
NIST CSF PR.AC-4
- ☐ Cloud-native IAM policy analyzer run at least annually to detect unused or over-broad permissions.
AWS IAM Access Analyzer / Azure AD Access Reviews

3. Kenya Data Protection Act 2019 Compliance

- ☐ Registered as a Data Controller and/or Data Processor with the Office of the Data Protection Commissioner (ODPC).
Kenya DPA 2019 — Part IV
- ☐ Data Protection Officer (DPO) appointed — internal or outsourced.
Kenya DPA 2019 — Section 24
- ☐ Personal data inventory completed: what's collected, where it's stored, who can access it, retention period.
Kenya DPA 2019 — Section 25
- ☐ Data Protection Impact Assessment (DPIA) completed for any high-risk processing (biometric data, large-scale profiling).
Kenya DPA 2019 — Section 31
- ☐ Consent for data collection is explicit, specific, and separate from other terms — no pre-ticked boxes.
Kenya DPA 2019 — Section 32
- ☐ Breach notification procedure documented and tested — able to notify the ODPC within 72 hours of discovery.
Kenya DPA 2019 — Section 43
- ☐ Data Processing Agreements (DPAs) signed with every third-party processor handling personal data on your behalf.
Kenya DPA 2019 — Section 41

4. Email Security — SPF, DKIM & DMARC

- ☐ SPF record published, correctly listing every authorized sending source for your domain.
RFC 7208
- ☐ DKIM signing enabled on all outbound mail, with keys at least 2048-bit.
RFC 6376
- ☐ DMARC record published, policy set to at least p=quarantine (p=reject once monitored and confirmed safe).
RFC 7489

- ☐ DMARC aggregate (rua) reports actively monitored monthly for unauthorized senders spoofing your domain.
RFC 7489
- ☐ Business email compromise safeguards in place — external-sender banners, verification step for payment-change requests.
CISA BEC Guidance
- ☐ Email gateway/provider filtering configured for phishing, malware attachments, and display-name impersonation.
NIST CSF PR.DS

5. Backup & Disaster Recovery Readiness

- ☐ Automated backups on a defined schedule for all production systems — not manual/ad-hoc.
NIST CSF PR.IP-4
- ☐ Backups follow the 3-2-1 rule: 3 copies, 2 media types, 1 copy offsite/off-region.
CISA Backup Guidance
- ☐ RTO and RPO formally defined per system, matched to real business tolerance — not guessed.
ISO 27001 A.17
- ☐ Backup restoration actually tested (not just backup-completion checked) at least quarterly.
CIS Control 11
- ☐ Backups encrypted at rest, with access controlled separately from production access.
CIS Control 11
- ☐ Business Continuity Plan covers realistic Kenya-specific scenarios — extended outage, fibre cut, payment-gateway downtime.
ISO 22301 principles
- ☐ Immutable/versioned backups in place to protect against ransomware deleting or encrypting backup copies.
CISA Ransomware Guide

6. Staff Security Awareness Scorecard

- ☐ Security awareness training completed by all system-access staff within the last 12 months.
ISO 27001 A.7.2
- ☐ Phishing simulations run at least twice yearly, with repeat-click staff given targeted follow-up training.
NIST CSF PR.AT
- ☐ Clear, simple incident-reporting process staff actually know — "who do I call if I clicked something bad."
NIST CSF RS.CO
- ☐ Password policy enforced technically — minimum length, no reuse, password manager provided or encouraged.
CIS Control 5
- ☐ BYOD/remote-work device policy covers patch level, disk encryption, and remote-wipe for lost devices.
CIS Control 4



Third-party/vendor system access is documented, time-limited, and reviewed — not standing and forgotten.

ISO 27001 A.15

Scoring guide: 34-40 checked — strong baseline, focus on the gaps. 20-33 — meaningful exposure, prioritize IAM/MFA and backups first. Under 20 — schedule a professional review before an incident forces the conversation.

Want a professional walkthrough of these results, or help closing the gaps? cloudgridafrica.com/#quote · info@cloudgridafrica.com

© CloudGrid Africa. This checklist is provided for general informational purposes and does not constitute legal advice on Kenya DPA 2019 compliance. Reviewed periodically against current NIST, CIS, OWASP, and ODPC guidance — corrections to info@cloudgridafrica.com.